

LAPORAN WORKSHOP DEVOPS

BAB 1 : Fondasi Teoretis dan Kerangka Kerja DevSecOps



Oleh:

Zhulva Priya Abhipraya (3126640034)

Dosen Pengajar:

Dr. Ferry Astika Saputra, ST, M.Sc

**PROGRAM STUDI SARJANA TERAPAN LANJUT JENJANG TEKNIK
INFORMATIKA
DEPARTEMEN TEKNIK INFORMATIKA DAN KOMPUTER
POLITEKNIK ELEKTRONIKA NEGERI SURABAYA
2026**

1. Tujuan Praktikum

1. Membangun sistem direktori kerja yang aman dan terisolasi untuk seluruh rangkaian praktikum DevSecOps.
2. Merekam versi komponen baseline sistem (Docker Engine, Compose, dan versi Kernel Linux) demi menjamin replikasi lingkungan laboratorium yang konsisten.
3. Memeriksa dan menganalisis konfigurasi opsi keamanan host (SecurityOptions) yang aktif pada Docker daemon untuk memahami batas-batas isolasi keamanan awal.
4. Menyusun dokumen Threat Statement (Pernyataan Ancaman) awal untuk mengidentifikasi aset, aktor ancaman, jalur serangan, dan dampak pada laboratorium.

2. Hasil Pelaksanaan Praktikum

A. Inisialisasi Struktur Direktori Kerja yang Aman

Struktur direktori kerja utama devsecops-lab berhasil dibuat menggunakan terminal PowerShell dengan subdirektori sensitif sebagai berikut:

- **app/** : Untuk menyimpan kode sumber aplikasi.
- **policy/** : Untuk mendefinisikan aturan keamanan berbasis kode (Policy-as-Code).
- **reports/** : Wadah penyimpanan laporan hasil pemindaian (security scan reports).
- **sbom/** : Wadah penyimpanan dokumen Software Bill of Materials (inventaris komponen dependensi).
- **keys/** : Tempat penyimpanan eksklusif untuk kunci enkripsi, kredensial, dan tanda tangan digital (signature).

Catatan Keamanan: Folder reports, sbom, dan keys diisolasi sepenuhnya dan tidak diletakkan di bawah web root aplikasi apa pun. Hal ini mencegah kebocoran laporan kerentanan atau kebocoran kunci enkripsi sensitif ke publik melalui browser.

B. Hasil Perekaman Baseline Sistem & Opsi Keamanan

Berdasarkan pengujian perintah docker info dan verifikasi versi di terminal, berikut adalah data baseline sistem laboratorium yang terdeteksi:

Parameter Baseline	Hasil Temuan Sistem	Analisis Risiko Keamanan
Kernel OS Host	6.18.33.2-microsoft-standard-WSL2	Sistem berjalan menggunakan subsistem WSL2 berbasis kernel Linux kustom Microsoft.
Security Options: seccomp	Profile: unconfined	Risiko Sedang/Tinggi: Docker daemon berjalan tanpa membatasi system call dari kontainer ke kernel host (unconfined). Jika kontainer berhasil disusupi, penyerang memiliki peluang lebih besar untuk mengeksploitasi celah kernel host.

Parameter Baseline	Hasil Temuan Sistem	Analisis Risiko Keamanan
Security Options: cgroupns	Aktif (cgroupns)	Sangat Baik: Menjamin isolasi ruang nama kontrol grup (control group namespaces), membatasi kontainer agar tidak dapat melihat atau mengutak-atik alokasi resource milik host atau kontainer lain.
Warning 1	DOCKER_INSECURE_NO_IPTABLES_RAW is set	Menunjukkan bahwa modul pembatasan iptables tertentu tidak dimuat secara penuh, yang dapat memengaruhi segmentasi jaringan kontainer.
Warning 2	daemon is not using the default seccomp profile	Memperkuat temuan bahwa profil keamanan filter system call (seccomp) default belum diterapkan dengan ketat pada daemon ini.

3. Analisis Hasil & Pembahasan

Temuan di atas membuktikan teori pada **Bab 1** bahwa munculnya opsi seccomp pada perintah pemeriksaan keamanan tidak serta merta menandakan sistem kita sudah sepenuhnya tangguh (hardened). Kasus di atas menunjukkan bahwa meskipun modul seccomp didukung oleh sistem, statusnya masih unconfined (bebas/tidak terbatas) sehingga pintu interaksi langsung kontainer ke kernel host masih terbuka lebar.

Hal ini menekankan pentingnya pendekatan **Shift-Left** dan otomatisasi audit keamanan di bab-bab mendatang (khususnya Bab 8 tentang Hardening). Kita harus secara proaktif memperketat konfigurasi Docker daemon dan membatasi izin kontainer melalui file konfigurasi sebelum dideploy ke lingkungan produksi.

4. Threat Statement (Pernyataan Ancaman) Laboratorium

"Pada lingkungan laboratorium DevSecOps ini, aset utama yang dilindungi meliputi kode sumber aplikasi di folder app, kredensial/kunci kriptografi di folder keys, serta dokumen integritas audit di folder reports dan sbom. Kami mengantisipasi aktor ancaman berupa penyerang eksternal oportunistik maupun kelalaian konfigurasi internal oleh pengembang. Jalur serangan yang diantisipasi meliputi eksploitasi port kontainer yang terekspos secara tidak aman ke jaringan publik, masuknya dependensi pihak ketiga yang memiliki celah keamanan kritis (vulnerable dependencies), serta bypass kontrol isolasi kernel host akibat status profil seccomp yang longgar (unconfined). Dampak terburuk dari keberhasilan serangan ini adalah terjadinya kebocoran kunci enkripsi privat, manipulasi laporan kepatuhan keamanan, hilangnya integritas aplikasi, atau pengambilalihan kendali penuh atas sistem operasi host oleh aktor luar secara ilegal."

5. Kesimpulan

Praktikum 1 telah berhasil menetapkan baseline awal laboratorium yang aman dan terukur. Meskipun sistem laboratorium saat ini masih memiliki celah default (seperti seccomp profile unconfined), pencatatan baseline ini memberikan fondasi data yang kuat bagi praktikan untuk merancang, menguji, dan memverifikasi perbaikan keamanan (security hardening) pada siklus-siklus praktikum berikutnya.

Dokumentasi Praktikum video : <https://drive.google.com/file/d/1jJQq-5o8P7m9Va4Rql0wTpvoLHcpNjk3/view?usp=sharing>